

GovSecure Third-Party AI Privacy Risk Assessment

Vendor Questionnaire and Evidence Review Pack

Purpose

Assess privacy, data protection, governance, and AI data-use risk in third-party AI vendors, deployers, and adopters — with a primary emphasis on vendor accountability.

Designed for use during onboarding, procurement review, renewal review, major product changes, and post-incident reassessment.

Version 1.0

This document includes section numbering, answer fields, evidence-request columns, reviewer risk scoring, red-flag triggers, and an executive summary page for internal reviewers.

Executive Summary for Reviewers

Complete after receiving the vendor response and evidence pack.

Vendor name		Assessment date	
Product / service		Review owner	
Business sponsor		Assessment status	Not Started / In Review / Complete
Use case summary		Overall risk rating	Low / Moderate / High / Critical
Data sensitivity	Public / Internal / Confidential / Sensitive / Regulated	High-impact use case?	Yes / No
Training use of customer data?	Yes / No / Partial	Cross-border transfers?	Yes / No / Partial
Top red flags		Decision recommendation	Approve / Conditionally Approve / Reject / Escalate
Required follow-ups		Target close date	

Risk Scoring Guidance

- 1 = Informational / low concern
- 2 = Minor concern / limited relevance
- 3 = Moderate concern / follow-up needed
- 4 = High concern / mitigation or leadership review needed
- 5 = Critical concern / automatic escalation if unresolved

Automatic Red-Flag Triggers

- Customer data is used for training, tuning, or product improvement by default.
- Vendor cannot explain retention, deletion scope, or storage locations.
- No privacy lead, no privacy program, or no DPA support.
- Cross-tenant exposure is possible or not clearly ruled out.
- Sensitive or regulated data is permitted without explicit safeguards.
- Broad human review occurs without strict controls.
- Subprocessors or transfer mechanisms are not disclosed.
- Recent privacy or security incident lacks clear remediation.

How to Complete This Questionnaire

- Vendor response: complete the 'Answer Field' area for each question or provide a linked workbook response.
- Evidence requested: attach or reference the supporting artifact where available.
- Reviewer notes / risk lens: reserved for GovSecure or internal reviewers after submission.
- Score: reviewer enters 1–5 after evaluating the response and evidence.
- Red-flag trigger: indicates conditions that should automatically trigger escalation or conditional approval.

Suggested response types: Yes / No; Yes / No / Partial; Select all that apply; Short answer; Long answer; Attachment required; Date.

Section 1 — Vendor / Provider Profile

12 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Legal company name	Short answer Vendor Response: _____	Company registration or legal entity record	Reviewer note: _____	1	No legal entity or ambiguous provider identity
Product / service name	Short answer Vendor Response: _____	Product overview or service description	Reviewer note: _____	1	Product being assessed clearly identified
Primary website	Short answer Vendor Response: _____	Public product page or documentation link	Reviewer note: _____	1	No public product information available
Headquarters country	Short answer Vendor Response: _____	Company profile or corporate registration	Reviewer note: _____	2	Headquarters or legal jurisdiction cannot be confirmed
Countries where service is delivered or supported	Long answer Vendor Response: _____	Service region list or support matrix	Reviewer note: _____	2	Material operations occur in high-risk or unknown jurisdictions
Primary business contact name and title	Short answer Vendor Response: _____	Business contact details	Reviewer note: _____	1	No accountable commercial contact
Privacy contact name and email	Short answer Vendor Response: _____	Privacy office or DPO contact details	Reviewer note: _____	4	No privacy contact or escalation channel
Security contact name and email	Short answer Vendor Response: _____	Security contact details	Reviewer note: _____	3	No security contact or escalation channel
Organization role	Select all that apply Vendor Response: _____	Role statement (provider, deployer, integrator, processor, controller, etc.)	Reviewer note: _____	3	Vendor cannot clearly state its legal or operational role
Briefly describe the AI product or service being assessed	Long answer Vendor Response: _____	Product overview, architecture summary, or model card	Reviewer note: _____	2	Product scope, intended purpose, or AI function unclear
Describe intended business use case(s) for the customer	Long answer Vendor Response: _____	Use case summary or implementation scope	Reviewer note: _____	3	Use case is open-ended, high impact, or not bounded
AI capabilities involved	Select all that apply Vendor Response: _____	Capability description (GenAI, ML, recommendation, agentic, biometric, profiling, etc.)	Reviewer note: _____	3	High-risk capability is involved without supporting controls

Section risk

Section owner /

summary		reviewer	
Open actions		Escalation required?	Yes / No

Section 2 — AI System Overview

8 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
What type of AI model(s) or services are used?	Select all that apply Vendor Response: _____ _____	Model architecture summary or model list	Reviewer note: _____	3	Model stack or provider dependencies are not disclosed
Identify all third-party model providers, cloud providers, subprocessors, or data partners involved	Long answer Vendor Response: _____ _____	Architecture diagram and third-party dependency list	Reviewer note: _____	4	Critical dependencies are withheld or materially incomplete
Does the solution process customer inputs in real time, store them, or both?	Yes / No / Partial Vendor Response: _____ _____	Data flow diagram or processing description	Reviewer note: _____	3	Storage or processing behavior is unclear
Does the solution use customer data for inference only, product improvement, model fine-tuning, training, analytics, or human review?	Select all that apply Vendor Response: _____ _____	Data use statement and contract terms	Reviewer note: _____	5	Customer data is used for training or improvement by default
Does the AI system make decisions, recommendations, or outputs that could materially affect individuals?	Yes / No Vendor Response: _____ _____	Use case impact statement	Reviewer note: _____	4	High-impact decision system exists without extra safeguards
If yes, describe the types of impact	Long answer Vendor Response: _____ _____	Impact assessment or use case classification	Reviewer note: _____	4	Potential effect on employment, access, financial health, or rights is not evaluated
Is human review required before high-impact outputs or actions are used?	Yes / No / Partial Vendor Response: _____ _____	Workflow, approval logic, or SOP	Reviewer note: _____	5	No human review for high-impact outputs or actions
Can the system take actions automatically on behalf of a user or organization?	Yes / No Vendor Response: _____ _____	Automation scope and permission design	Reviewer note: _____	4	Autonomous actions exist without scoping or appropriate thresholds

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 3 — Personal Data and Privacy Scope

10 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
What categories of personal data may be processed by the service?	Select all that apply Vendor Response: _____ _____	Data inventory or processing category list	Reviewer note: _____	4	Extensive personal data categories are processed without minimization
What categories of sensitive or regulated data may be processed?	Select all that apply Vendor Response: _____ _____	Sensitive data inventory or control statement	Reviewer note: _____	5	Sensitive or regulated data is processed without being permitted without explicit safeguards
Is the customer permitted to submit sensitive personal data into the service?	Yes / No / Partial Vendor Response: _____ _____	Usage policy or contract term	Reviewer note: _____	5	Sensitive data submission is not allowed by default
If yes, what controls exist to restrict, mask, filter, classify, or protect that data?	Long answer Vendor Response: _____ _____	DLP, filtering, classification, masking, or policy evidence	Reviewer note: _____	5	No preventive or detective controls for sensitive data
Does the system collect personal data directly from users, indirectly from customers, or from third-party sources?	Select all that apply Vendor Response: _____ _____	Collection method description	Reviewer note: _____	3	Data source paths are not documented
Does the service infer new personal data, traits, profiles, or behavioral insights from submitted data?	Yes / No / Partial Vendor Response: _____ _____	Profiling or inference documentation	Reviewer note: _____	5	Vendor creates inferred profiles without transparency or controls
Does the solution generate content that may contain personal data from training data, retrieval data, or prior prompts?	Yes / No / Partial Vendor Response: _____ _____	Leakage testing or system card	Reviewer note: _____	5	Potential regeneration of personal data is not tested or addressed
Can the solution return data belonging to another customer, tenant, or user?	Yes / No Vendor Response: _____ _____	Tenant isolation design and testing evidence	Reviewer note: _____	5	Cross-tenant leakage is not possible or not ruled out
Describe all data elements required to use the service safely and effectively	Long answer Vendor Response: _____ _____	Minimum data requirement statement	Reviewer note: _____	3	Required data scope appears excessive
Describe any data elements that are optional but commonly submitted by customers	Long answer Vendor Response: _____ _____	Usage guidance or best-practice documentation	Reviewer note: _____	3	Optional data includes unnecessary or sensitive content

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 4 — Purpose Limitation and Data Use

8 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Describe the specific purposes for which customer data is processed	Long answer Vendor Response: _____	Purpose specification statement	Reviewer note: _____	4	Purposes are broad, vague, or not limited
Is customer data used only to deliver the contracted service?	Yes / No / Partial Vendor Response: _____	Contract language or privacy notice	Reviewer note: _____	5	Customer data is used for purposes beyond contracted service delivery
Is customer data ever used for training, model improvement, benchmarking, analytics, advertising, profiling, research, or sharing with third parties?	Select all that apply Vendor Response: _____	Privacy terms and data use statement	Reviewer note: _____	5	Secondary data use exists without explicit opt-in
Can customers opt out of model training, product improvement, or analytics use of their data?	Yes / No / Partial Vendor Response: _____	Admin settings, DPA clause, or product controls	Reviewer note: _____	5	No opt-out for non-essential secondary uses
Are opt-out settings enabled by default or only upon request?	Short answer Vendor Response: _____	Configuration guide or contract language	Reviewer note: _____	4	Privacy-protective settings are not default
If data is de-identified or anonymized, describe the method and whether re-identification risk is assessed	Long answer Vendor Response: _____	De-identification standard or assessment summary	Reviewer note: _____	4	Claims of anonymization are unsupported
Are prompts, uploads, outputs, embeddings, logs, or telemetry reused for any secondary purpose?	Yes / No / Partial Vendor Response: _____	Data lifecycle description	Reviewer note: _____	5	Prompts or outputs are reused without customer awareness
If yes, describe each secondary purpose clearly	Long answer Vendor Response: _____ _____	Detailed secondary use disclosure	Reviewer note: _____	5	Secondary purpose is ambiguous or materially broad

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 5 — Data Retention, Deletion, and Disposal

7 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
What is the default retention period for prompts, uploads, outputs, histories, embeddings, logs, metadata, and human review content?	Long answer Vendor Response: _____	Retention schedule	Reviewer note: _____	5	Retention periods are not defined or are excessive
Can customers configure retention periods?	Yes / No / Partial Vendor Response: _____	Admin guide or product settings evidence	Reviewer note: _____	4	No configurable retention periods or customer-controlled data
Can customers delete submitted data, prompts, outputs, and logs on demand?	Yes / No / Partial Vendor Response: _____	Deletion process documentation	Reviewer note: _____	5	Customer deletion rights not supported
When data is deleted, is it removed from production, backups, indexes, vector stores, training datasets, fine-tunes, and logs?	Yes / No / Partial Vendor Response: _____	Deletion scope statement	Reviewer note: _____	5	Deletion excludes major storage layers
Describe deletion timelines and any exceptions	Long answer Vendor Response: _____	Deletion SLA or retention exceptions	Reviewer note: _____	4	Deletion timing is unclear or materially delayed
If customer data is used in training or fine-tuning, can that data later be removed or unlearned?	Yes / No / Partial Vendor Response: _____	Unlearning or retraining process statement	Reviewer note: _____	5	No removal path for training data on customer data
Describe secure disposal procedures at end of contract	Long answer Vendor Response: _____	Offboarding and destruction procedure	Reviewer note: _____	4	End-of-contract disposal procedures undefined

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 6 — Data Sharing, Subprocessors, and Cross-Border Transfers

9 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
List all subprocessors involved in hosting, inference, storage, support, analytics, review, or model operations	Long answer Vendor Response: _____	Current subprocessor list	Reviewer note: _____	5	Subprocessors are not disclosed
Do subprocessors receive personal data, prompts, outputs, or metadata?	Yes / No / Partial Vendor Response: _____	Data flow diagram or subprocessor data map	Reviewer note: _____	4	Vendor cannot specify subprocessors receive
Are subprocessors contractually restricted from using customer data for their own purposes?	Yes / No / Partial Vendor Response: _____	Subprocessor contract terms or summary	Reviewer note: _____	5	Subprocessors may reuse customer data
In which countries is customer data stored, processed, accessed, or supported?	Long answer Vendor Response: _____	Data residency and support location statement	Reviewer note: _____	4	Storage or access locations are unknown
Are cross-border data transfers performed?	Yes / No Vendor Response: _____	Transfer map or regional processing statement	Reviewer note: _____	4	Cross-border transfers without transparency
If yes, what transfer mechanism is used?	Select all that apply Vendor Response: _____	SCCs, adequacy, UK IDTA, DPF, or equivalent evidence	Reviewer note: _____	5	No lawful transfer mechanism for restricted transfers
Can customers choose data residency or processing region?	Yes / No / Partial Vendor Response: _____	Regional hosting options or contract term	Reviewer note: _____	3	No regional choice for sensitive workloads
Can vendor support personnel access customer data from outside the chosen region?	Yes / No / Partial Vendor Response: _____	Support access control description	Reviewer note: _____	4	Remote support access bypasses region commitments
Describe controls for international transfers and remote support access	Long answer Vendor Response: _____	Remote access control standard	Reviewer note: _____	4	Support access is broad, uncontrolled, or unlogged

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 7 — Privacy Governance and Accountability

8 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Do you maintain a documented privacy program?	Yes / No / Partial Vendor Response: _____	Privacy program summary or policy	Reviewer note: _____	4	No formal privacy program
Do you have a designated privacy officer, DPO, or equivalent accountable leader?	Yes / No Vendor Response: _____	Org chart or privacy governance statement	Reviewer note: _____	5	No named privacy accountability
Do you conduct privacy impact assessments, DPIAs, or AI-specific risk assessments for the product?	Yes / No / Partial Vendor Response: _____	Assessment methodology or sample summary	Reviewer note: _____	4	No privacy impact assessments for material AI processes
Is privacy-by-design formally incorporated into product development?	Yes / No / Partial Vendor Response: _____	SDLC control or design review evidence	Reviewer note: _____	4	No privacy-by-design requirements
Are AI product changes subject to privacy review before release?	Yes / No / Partial Vendor Response: _____	Change management and review workflow	Reviewer note: _____	4	Material AI changes byproduct of privacy review
Do you maintain records of processing activities relevant to this service?	Yes / No / Partial Vendor Response: _____	ROPA or data processing record	Reviewer note: _____	3	Processing activities are not documented
Do you have documented policies for privacy, retention, access control, AI governance, training data governance, data subject rights, and incident response?	Yes / No / Partial Vendor Response: _____	Policy set or policy index	Reviewer note: _____	4	Core governance policies missing or immature
Are employees trained on privacy and responsible AI requirements?	Yes / No / Partial Vendor Response: _____	Training completion summary or program description	Reviewer note: _____	3	No workforce training on privacy and responsible AI

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 8 — Data Subject Rights and User Transparency

7 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Can customers fulfill data subject rights requests using your service?	Yes / No / Partial Vendor Response: _____	DSAR support procedure	Reviewer note: _____	4	Customers cannot operationalize rights re
Can personal data be located, exported, corrected, deleted, or restricted upon request?	Yes / No / Partial Vendor Response: _____	Rights fulfillment workflow	Reviewer note: _____	5	Core rights operations unsupported
Does your service support lawful response to access, deletion, correction, portability, objection, or restriction requests?	Yes / No / Partial Vendor Response: _____	Rights matrix or process map	Reviewer note: _____	5	Rights support is partial no clear limitations
Are end users informed when they are interacting with AI?	Yes / No / Partial Vendor Response: _____	Notice language or UI evidence	Reviewer note: _____	3	No notice when users i with AI
Are customers provided with privacy disclosures, notices, or model usage explanations they can reuse?	Yes / No / Partial Vendor Response: _____	Customer-facing notices or guidance	Reviewer note: _____	3	Customers receive no transparency support materials
Does the system support output traceability or explainability for privacy-relevant outputs?	Yes / No / Partial Vendor Response: _____	Audit trail or explainability feature evidence	Reviewer note: _____	4	Privacy-relevant outpu not traceable
If the service profiles individuals or supports decisions affecting them, what transparency controls exist?	Long answer Vendor Response: _____	Transparency control summary	Reviewer note: _____	5	Profiling or decision su exists without disclosu challenge path

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 9 — AI Training, Fine-Tuning, and Model Governance

10 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
What sources were used to train the model(s)?	Long answer Vendor Response: _____	Training data source summary or model card	Reviewer note: _____	4	Training data provenance unclear
Were personal data or public internet sources included in training?	Yes / No / Partial Vendor Response: _____	Training data composition statement	Reviewer note: _____	5	Personal data use in training is not disclosed
How was training data screened for privacy, consent, licensing, and appropriateness?	Long answer Vendor Response: _____	Training data governance standard	Reviewer note: _____	5	No screening for privacy, consent, or licensing
Are customer prompts, files, outputs, or telemetry used to fine-tune models?	Yes / No / Partial Vendor Response: _____	Fine-tuning policy or data use setting	Reviewer note: _____	5	Customer content is used for fine-tuning without explicit authorization
Can customer-specific models or isolated fine-tunes be created?	Yes / No / Partial Vendor Response: _____	Deployment model options	Reviewer note: _____	3	Customer-specific isolated models are unavailable for sensitive cases
If yes, are those isolated from other customers?	Yes / No / Partial Vendor Response: _____	Isolation design evidence	Reviewer note: _____	5	Fine-tunes or models are not isolated
Are training, fine-tuning, or retrieval datasets reviewed for sensitive, inaccurate, or excessive personal data?	Yes / No / Partial Vendor Response: _____	Dataset review evidence	Reviewer note: _____	4	No review of privacy risk in training datasets
Do you test for memorization, leakage, or regeneration of personal data?	Yes / No / Partial Vendor Response: _____	Privacy leakage test results or summary	Reviewer note: _____	5	No testing for memorization or leakage
Do you monitor for model drift or changes that affect privacy risk?	Yes / No / Partial Vendor Response: _____	Monitoring procedure or model governance docs	Reviewer note: _____	4	No monitoring for privacy risk impacting changes
Are model updates communicated to customers before or after deployment?	Yes / No / Partial Vendor Response: _____	Release communication policy	Reviewer note: _____	3	Material updates are not communicated or non-transparent

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 10 — Human Review, Annotation, and Access to Content

7 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Do employees, contractors, reviewers, or annotators access customer prompts, files, or outputs?	Yes / No / Partial Vendor Response: _____	Access model or review workflow	Reviewer note: _____	5	Human access exists w transparency or strict controls
If yes, for what purposes are human reviewers used?	Select all that apply Vendor Response: _____	Human review purpose statement	Reviewer note: _____	4	Human access extends beyond necessary purp
Is access role-based and logged?	Yes / No / Partial Vendor Response: _____	Access control and logging standard	Reviewer note: _____	5	Human access is not ro based or logged
Is access restricted to approved personnel with confidentiality obligations?	Yes / No / Partial Vendor Response: _____	Confidentiality terms or onboarding standard	Reviewer note: _____	4	Reviewers are not subj confidentiality and scr
Are human reviewers located in specific countries or regions?	Long answer Vendor Response: _____	Reviewer location disclosure	Reviewer note: _____	3	Reviewer locations are disclosed
Can customers opt out of human review where not legally or operationally required?	Yes / No / Partial Vendor Response: _____	Opt-out configuration or contract term	Reviewer note: _____	4	No opt-out for discretio human review
Describe monitoring and controls around human access to content	Long answer Vendor Response: _____	Monitoring evidence or admin oversight procedure	Reviewer note: _____	4	Human access monitor weak or undocumente

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 11 — Security Controls Supporting Privacy

12 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Is customer data encrypted in transit and at rest?	Yes / No / Partial Vendor Response: _____	Encryption standard or architecture summary	Reviewer note: _____	4	No encryption at rest or in transit
Are tenant environments logically or physically segregated?	Yes / No / Partial Vendor Response: _____	Tenant isolation architecture	Reviewer note: _____	5	Tenant segregation is unclear
Are access controls role-based and least-privilege?	Yes / No / Partial Vendor Response: _____	Access control standard	Reviewer note: _____	4	Privileged access is broadly uncontrolled
Is MFA required for privileged access?	Yes / No / Partial Vendor Response: _____	Identity and access standard	Reviewer note: _____	4	No MFA for privileged access
Are logs maintained for administrator access and sensitive actions?	Yes / No / Partial Vendor Response: _____	Audit logging policy	Reviewer note: _____	4	Admin access or sensitive actions are not logged
Are vulnerability management and penetration testing performed?	Yes / No / Partial Vendor Response: _____	Recent pen test summary or vuln management standard	Reviewer note: _____	3	No security assurance or testing
Are secrets, credentials, and API keys securely managed?	Yes / No / Partial Vendor Response: _____	Secrets management standard	Reviewer note: _____	4	Credentials or keys are not securely managed
Are embeddings, vector stores, and retrieval layers protected with access control?	Yes / No / Partial Vendor Response: _____	RAG security design or access control evidence	Reviewer note: _____	4	Retrieval layers are not protected
Are prompts and outputs included in security logging?	Yes / No / Partial Vendor Response: _____	Logging scope statement	Reviewer note: _____	3	No logging coverage for prompts/outputs where needed
Does the service support customer-managed keys, SSO, or regional isolation?	Select all that apply Vendor Response: _____	Security feature matrix	Reviewer note: _____	2	No enterprise security features for sensitive deployments
Has the product experienced any privacy or security incident involving customer data in the last 24 months?	Yes / No Vendor Response: _____	Incident disclosure or assurance statement	Reviewer note: _____	5	Recent material incident without clear remediation
If yes, describe the incident, impact, and remediation	Long answer Vendor Response: _____	Incident summary or RCA	Reviewer note: _____	5	Incident disclosure lacks scope, cause, or remediation detail

Section risk summary

Section owner / reviewer

Open actions		Escalation required?	Yes / No
--------------	--	----------------------	----------

Section 12 — High-Risk and Regulated Use Cases

5 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Is the service intended for or commonly used in hiring, lending, insurance, education, healthcare, law enforcement, public sector, biometrics, children, critical infrastructure, legal advice, trading, or eligibility decisions?	Select all that apply Vendor Response: _____ _____	Use case statement or marketing materials	Reviewer note: _____	5	High-risk use case supplied without sector-specific controls
Are there prohibited use cases defined by the vendor?	Yes / No / Partial Vendor Response: _____ _____	Acceptable use policy or prohibited use list	Reviewer note: _____	4	No prohibited use framework
Are customers prevented technically or contractually from using the system in prohibited contexts?	Yes / No / Partial Vendor Response: _____ _____	Terms, abuse controls, or configuration evidence	Reviewer note: _____	5	Prohibited uses are not enforced
Are additional safeguards required for high-risk or regulated deployments?	Yes / No / Partial Vendor Response: _____ _____	High-risk deployment control pack	Reviewer note: _____	4	No enhanced safeguards for regulated use
Does the vendor provide documentation to support compliance reviews in regulated sectors?	Yes / No / Partial Vendor Response: _____ _____	Compliance pack, whitepaper, or evidence kit	Reviewer note: _____	3	No documentation for regulated buyers

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 13 — Incident Response and Breach Notification

6 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Do you maintain a documented incident response plan covering privacy and AI-specific incidents?	Yes / No / Partial Vendor Response: _____	IR plan or playbook summary	Reviewer note: _____	4	No documented incident response for AI/privacy events
Does the plan address data leakage, model leakage, cross-tenant exposure, harmful output, prompt injection, unauthorized retention, and human review misuse?	Yes / No / Partial Vendor Response: _____	IR scenario matrix or playbook details	Reviewer note: _____	5	AI-specific incidents are not addressed
What is your breach or incident notification timeline?	Short answer Vendor Response: _____	Contract term or IR commitment	Reviewer note: _____	4	Notification timeline is too long or too slow
What is your process for customer communication during an incident?	Long answer Vendor Response: _____	Communication plan or SOP	Reviewer note: _____	3	Customer communication process is vague
Are affected customers provided with root cause analysis and remediation details?	Yes / No / Partial Vendor Response: _____	Post-incident communication template	Reviewer note: _____	3	No RCA or remediation transparency
Are incidents tracked and used to improve privacy controls?	Yes / No / Partial Vendor Response: _____	Lessons learned process	Reviewer note: _____	3	No corrective action or control improvement loop

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 14 — Contractual and Legal Commitments

7 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Will you sign a DPA or equivalent privacy agreement?	Yes / No / Partial Vendor Response: _____	DPA template	Reviewer note: _____	5	Vendor will not sign a DPA
Do you define your role as controller, processor, service provider, or another legally relevant role?	Short answer Vendor Response: _____	Role definition in contract or privacy terms	Reviewer note: _____	4	Legal role is undefined or inconsistent
Will you contractually commit not to use customer data for model training without explicit authorization?	Yes / No / Partial Vendor Response: _____	Contract clause or DPA statement	Reviewer note: _____	5	No contractual restriction on training use
Will you disclose subprocessors and notify customers of changes?	Yes / No / Partial Vendor Response: _____	Subprocessor notice commitment	Reviewer note: _____	4	No change notice for subprocessors
Will you support audits, security reviews, or evidence requests?	Yes / No / Partial Vendor Response: _____	Audit/right-to-assess language	Reviewer note: _____	3	No support for reasonable assurance requests
Do you offer contractual commitments for deletion, retention, region, and incident notification?	Yes / No / Partial Vendor Response: _____	Contract terms summary	Reviewer note: _____	4	Core commitments are not contractually available
Are limitations, exclusions, or exceptions to privacy commitments documented clearly?	Yes / No / Partial Vendor Response: _____	Contract exception list	Reviewer note: _____	3	Material exceptions are hidden or ambiguous

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Section 15 — Attestations and Evidence

4 questions

Question	Answer Field	Evidence Requested	Reviewer Notes / Risk Lens	Score	Red-Flag Trigger
Please provide available privacy, AI, security, and compliance artifacts (privacy policy, whitepaper, DPA, subprocessors list, retention schedule, data flow diagram, AI governance policy, model card, SOC/ISO certificates, pen test summary, IR summary, PIA summary, residency documentation)	Attachment required Vendor Response: _____	Evidence package	Reviewer note: _____	5	Vendor declines to provide basic supporting evidence
Has all information provided in this questionnaire been reviewed for accuracy?	Yes / No Vendor Response: _____	Signed attestation	Reviewer note: _____	4	No formal attestation of accuracy
Name, title, and signature of authorized respondent	Short answer Vendor Response: _____	Signed response cover page or e-signature	Reviewer note: _____	3	No authorized respondent
Date completed	Date Vendor Response: _____	Completed questionnaire date	Reviewer note: _____	1	Questionnaire is undated

Section risk summary		Section owner / reviewer	
Open actions		Escalation required?	Yes / No

Appendix A — Risk Rating Legend

Score	Rating	Interpretation
1	Informational	No meaningful privacy risk identified. Evidence still should support the response.
2	Minor	Limited issue or low-relevance gap. Track if repeated across related controls.
3	Moderate	Notable concern. Clarification, mitigation, or follow-up evidence needed.
4	High	Material concern. Escalate to business owner, privacy, legal, or security leadership.
5	Critical	Automatic escalation if unresolved. Usually blocks approval or requires executive exception.

Appendix B — Reviewer Disposition

Recommended decision	Approve / Conditionally Approve / Reject / Escalate
Key conditions	
Residual privacy risk	
Approving authority	
Date	